API_CONTRACTS

Status: Draft v1. Base path /api/v1. JSON only. Session cookie auth. Exact request and response schemas will be written as JSON Schema files in backend/contracts/ during implementation.

1. Conventions

- Auth: httpOnly session cookie. Mutating requests also need a CSRF token (header).
- Every request is validated against a schema. Unknown fields are rejected.
- Every response carries a correlationId.
- Error shape: { error: { code, message, correlationId } }. No stack traces, paths or tokens.
- Ownership: every workflow route checks that the workflow belongs to the logged-in user. Other users get 404.
- Mutating workflow routes check the current state and return 409 STATE_CONFLICT if not allowed.
- Approve, execute and push routes are idempotent.

2. Auth

Method and path	Purpose	Notes
GET /auth/github	Start OAuth	Creates state value. Requests write access because work is saved on a GitHub branch. Exact scopes to verify.
GET /auth/github/callback	OAuth callback	Verifies state, creates session, redirects to home. Banned users denied.
POST /auth/logout	End session	
GET /me	Current user	Returns id, login, avatar, limits and usage. Never returns tokens.

Method and path	Purpose	Notes
POST /auth/push-access	Re-authorize if write access is missing or expired	Used only if write access is missing. Redirects to GitHub.

3. Repos

Method and path	Purpose	Notes
GET /repos	List the user's own personal public repos	Server filters owner equals user, private false.

4. Workflows

Method and path	Purpose	Allowed state	Result
POST /workflows	Create from repo name and branch	none	Verifies ownership, public, personal. Pins SHA. Enqueues snapshot and creates the work branch on GitHub. 201
GET /workflows	List my workflows	any	Paginated
GET /workflows/:id	Status, state, profile, error	any	
POST /workflows/:id/cancel	Cancel	non-terminal	200
DELETE /workflows/:id	Delete workflow data	terminal or cancelled first	Verified deletion
GET /workflows/:id/events	Progress updates (polling or server-sent events)	any	

5. Findings, plan, approval

Method and path	Purpose	Allowed state
GET /workflows/:id/profile	Languages, frameworks, package managers with evidence	ANALYZED or later
GET /workflows/:id/findings	Findings list (filter by type, severity)	FINDINGS_READY or later
GET /workflows/:id/plan	Plan operations with risk and files	PLAN_READY or later
PUT /workflows/:id/plan/selection	Choose operations to enhance	PLAN_READY
POST /workflows/:id/approve	Approve selected operations. Body: planId, opIds, extraConfirmedOpIds	PLAN_READY
POST /workflows/:id/approve/withdraw	Withdraw before execution	APPROVED

The approve route re-checks: same user, SHA unchanged, operations belong to the plan, extra confirmation present for high risk or delete.

6. Review and delivery

Method and path	Purpose	Allowed state
GET /workflows/:id/review	Diff, manifest, static check results, warnings, limitations	IN_REVIEW
GET /workflows/:id/diff	Raw diff text	IN_REVIEW
POST /workflows/:id/push-permission	Explicit permission to open the PR. Body: confirm true, planId	IN_REVIEW
POST /workflows/:id/push	Verify branch and SHA, open PR from the work branch	PUSH_PERMITTED

Commits and PRs never target main. Obsidian never forces and never merges.

7. Account and admin

Method and path	Purpose
DELETE /me/data	Delete all my data (cancels active jobs first)
POST /admin/users/:id/ban	Ban a user (admin only)
POST /admin/users/:id/unban	Unban
GET /health	Liveness check

8. Internal API (backend to aiServices)

Not public. Protected by a shared secret or private network.

Method and path	Purpose
POST /ai/summarize	Project purpose and architecture summary from profile and excerpts
POST /ai/findings	Suggest findings with file and line evidence
POST /ai/plan	Suggest enhancement operations

All payloads have JSON Schema on both sides. The backend validates every response and discards anything that fails schema or scope checks (for example files not in the snapshot).

9. Error codes

Code	HTTP	Meaning
UNAUTHENTICATED	401	No valid session
USER_BANNED	403	Account blocked
REPO_NOT_OWNED	403	Repo owner is not the user

Code	HTTP	Meaning
REPO_PRIVATE	403	Private repos are not supported
REPO_NOT_PERSONAL	403	Organization repo
WORKFLOW_NOT_FOUND	404	Missing or not yours
STATE_CONFLICT	409	Action not allowed in current state
APPROVAL_STALE	409	SHA changed or approval no longer valid
OP_OUT_OF_SCOPE	422	Operation touches a file outside snapshot or plan
EXTRA_CONFIRMATION_REQUIRED	422	High-risk operation not confirmed
SNAPSHOT_TOO_LARGE	422	Repo exceeds limits
BRANCH_PROTECTED	403	Push to main refused
PUSH_PERMISSION_MISSING	403	No explicit permission
RATE_LIMITED	429	Too many requests
DAILY_LIMIT_REACHED	429	Workflow limit for today
AI_LIMIT	429	AI usage limit reached
AI_UNAVAILABLE	503	AI failed. Rule-based results still shown.
GITHUB_UNAVAILABLE	503	GitHub API down or rate limited
STEP_TIMEOUT	500	A step took too long
INTERNAL_ERROR	500	Unexpected. Details only in logs.

10. Contract tests

Each route has tests for: no session, wrong user, wrong state, invalid body, and the happy path. Cross-user access must return 404.